

DCSync Limited Output Evidence Report

Internal Network & Active Directory Pentest Evidence Documentation

Field	Details
Test Area	DCSync limited output
Evidence Source	18-dcsync-domain-hashes-dumped.png
Result Type	Domain hash dump evidence
Primary Tool / Component	Impacket secretsdump
MITRE ATT&CK Mapping	T1003.006 - DCSync
Document Purpose	Professional GitHub-ready evidence report with redacted screenshot and interpretation.

This report documents one specific evidence row from the AD Network assessment. It is intentionally evidence-specific, not a generic attack tutorial. Sensitive values have been blurred or represented as redacted placeholders for safe portfolio publication.

1. Embedded Evidence Screenshot

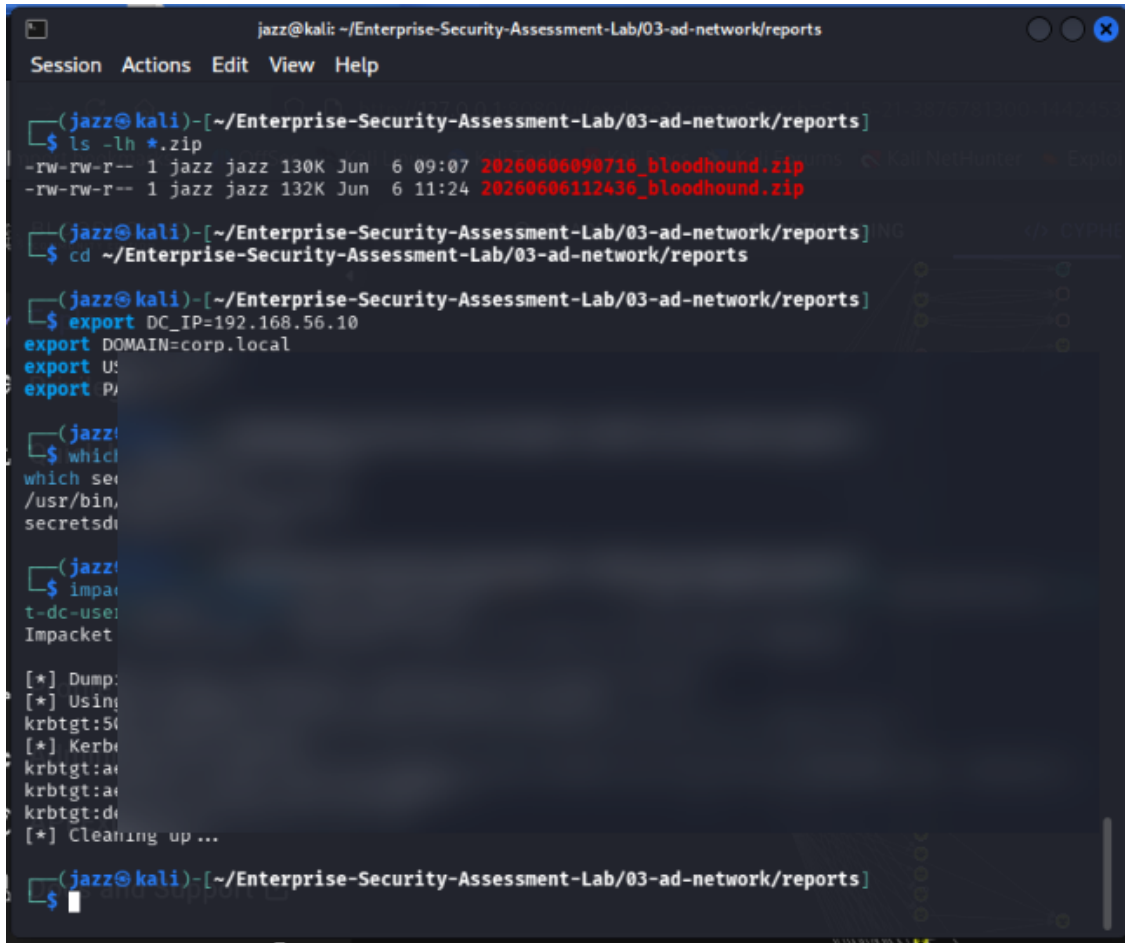


Figure 1 - Redacted evidence screenshot: 18-dcsync-domain-hashes-dumped.png

What this screenshot proves

The screenshot shows DCSync-style output from `secretsdump`. Domain hashes and Kerberos key material are blurred.

Evidence Context

Area	Value
Testing Phase	Domain Replication Rights Abuse Validation
Tool / Component	Impacket secretsdump
Objective	Demonstrate how replication privileges can be abused in a lab to request credential material from the domain controller.
Result Type	Domain hash dump evidence

2. Evidence-Specific Methodology

This section explains how this evidence fits into the overall internal network and Active Directory attack path. The goal is to demonstrate professional testing logic, not simply show a terminal screenshot.

- Use a lab account with appropriate replication rights or domain-level privileges.
- Run secretsdump against the domain controller.
- Capture limited output for evidence.
- Blur hashes, Kerberos keys, account secrets, and paths.

Command / Workflow Used

```
secretsdump.py <DOMAIN>/<USER>:<REDACTED_PASSWORD>@<DC_IP> -just-dc  
# Optional: -just-dc-user <USER> for limited user extraction
```

Sanitized Output Style

```
[*] Dumping Domain Credentials  
<REDACTED_ACCOUNT>:<RID>:<LM_HASH>:<NT_HASH>:::  
krbtgt:<REDACTED_HASH_MATERIAL>
```

Assessment Interpretation

The evidence supports the result type: Domain hash dump evidence. In a professional assessment, this evidence would be paired with the exact testing scope, timestamps, target identifiers, and remediation ownership. For GitHub publication, the report intentionally avoids showing live secrets, passwords, hashes, or reusable credential material.

3. Risk Analysis

DCSync can expose domain credential material, including krbtgt secrets. This is a critical domain compromise condition in real environments.

Why this matters in enterprise AD environments

- Active Directory attacks often chain multiple medium-risk issues into domain compromise.
- Credential material, even when not plaintext, can become dangerous if cracking, relaying, or alternate authentication is possible.
- Graph-based permissions and relationship analysis is necessary because AD risk is often hidden in group nesting and delegated rights.
- Evidence must be documented clearly so defenders can connect the technical finding to a specific control gap.

Recommended Remediation

- Restrict Replicating Directory Changes permissions.
- Audit accounts with replication rights.
- Monitor DCSync-like behaviour.
- Protect Domain Admin accounts.
- Rotate krbtgt after confirmed domain compromise.

Detection and Monitoring Opportunities

- Correlate authentication events with unusual source hosts and off-hours activity.
- Monitor SMB, LDAP, Kerberos, and replication-related event patterns.
- Alert on abnormal use of administrative protocols and credential dumping indicators.
- Review domain privilege assignments and privileged group membership changes regularly.

4. GitHub Publication and Redaction Guidance

This report is prepared for safe GitHub portfolio publication. The embedded screenshot has been treated as evidence, but sensitive material must not be recoverable or readable.

Sensitive Item	Action for GitHub
NTLM / NetNTLMv2 hashes	Blur or remove completely. Never publish reusable hash material.
Kerberos TGS / krb5tgs values	Blur or replace with <REDACTED_TICKET>.
Plaintext passwords	Do not publish. Replace with <REDACTED_PASSWORD>.
DCSync / NTDS hashes	Treat as domain compromise material and fully redact.
Internal IPs / domain names	May remain for lab context, but redact if privacy is required.
Username / service accounts	Keep only if lab-only; otherwise redact or generalize.

Suggested GitHub Link

[Open Report](./reports/evidence/09-dcsync-limited-output-evidence-report.pdf)

Professional Note

This document should be stored with the AD Network module reports, preferably under 03-ad-network/reports/evidence/. It is designed to replace a plain screenshot filename in the Evidence-Based Testing Summary table with a professional clickable report.